

Key Concepts

- **SAML** — enterprise SSO protocol; Identity Provider issues a signed XML assertion proving user identity
- **SSO (Single Sign-On)** — log in once at IdP, access multiple apps without re-authenticating
- **Identity Provider (IdP)** — manages identities, signs and issues SAML assertions (Okta, Azure AD, ADFS)
- **Service Provider (SP)** — the app being accessed (Salesforce, Jira, Slack)
- **SAML Assertion** — signed XML document containing user identity and attributes
- **Signing** — IdP signs assertion with its private key; SP verifies with IdP's public key (private key never leaves IdP)

The 3 Actors

Actor	Role	Example
User	The person logging in	Employee
Identity Provider (IdP)	Issues signed assertions	Okta, Azure AD, ADFS
Service Provider (SP)	App being accessed	Salesforce, Jira, Slack

How It Works

1. User visits Salesforce (SP) – not logged in
2. Salesforce redirects to company IdP (Okta)
3. User logs in once at Okta
4. Okta generates SAML Assertion (XML), signs it with its private key
5. Browser POSTs the assertion to Salesforce via HTML form
6. Salesforce verifies signature using IdP's public key
7. User is in – no Salesforce credentials needed

```

User          Salesforce (SP)          Okta (IdP)
|             |                       |
|-- visit ----->|                   |
|<-- redirect to Okta -----|       |
|-- login at Okta ----->|         |
|                               |     | generate SAML Assertion
|                               |     | sign with private key
|<-- browser form POST (assertion) ----|
|-- POST assertion -->|             |
|                               |     | verify signature
|                               |     | (public key)
|<-- access granted --|             |

```

SAML Assertion (XML)

Contains:

- Who the user is (**NameID** — usually email or employee ID)
- Attributes (name, role, department)
- Issuer (IdP)
- Validity period
- Digital signature

SAML vs OIDC

	SAML	OIDC
Format	XML	JSON / JWT
Year	2002	2014
Transport	Browser form POST	HTTP redirect + backend call
Complexity	High	Lower
Best for	Enterprise SSO, legacy systems	Modern web, mobile, APIs
Identity token	SAML Assertion (XML)	ID Token (JWT)
Signing	XML digital signature	JWT signature (HMAC/RSA)

Key Distinction — Signing

- IdP signs the assertion with its **private key** (never shared)
- SP verifies the signature with IdP's **public key**
- Private key stays at the IdP — only the signed assertion travels

Industry Examples

- **Okta + Salesforce** — enterprise SAML SSO; employees access Salesforce via Okta identity
- **Azure AD** — SAML federation for Office 365, enterprise SaaS apps
- **ADFS (Active Directory Federation Services)** — Microsoft's on-prem SAML IdP
- **Universities** — SAML for student SSO across library, email, learning management systems

Interview Questions

Q: What is SAML and what problem does it solve?

SAML is an enterprise SSO protocol. It lets users log in once at a central Identity Provider and access multiple Service Providers without re-authenticating. The IdP issues a signed XML assertion proving who the user is; the SP trusts it based on the signature.

Q: How does SAML signing work?

The IdP signs the SAML assertion with its private key. The private key never leaves the IdP. The Service Provider verifies the signature using the IdP's public key. This ensures the assertion wasn't tampered

with and came from a trusted source.

Q: How does SAML differ from OIDC?

Both achieve federated identity / SSO. SAML is older, uses XML, and relies on browser form POSTs — dominant in enterprise/legacy systems. OIDC is newer, uses JWT and HTTP redirects, and is preferred for modern web and mobile apps due to its simplicity.

Q: When would you choose SAML over OIDC?

When integrating with enterprise systems that already use SAML — Salesforce, Workday, legacy SaaS. Greenfield modern apps should default to OIDC. Many IdPs (Okta, Azure AD) support both.